

Safeguard 2.2: Ensure Authorized Software is Currently Supported

Asset Type: Software	Security Function: Identify	IG1 IG2 IG3
-----------------------------	------------------------------------	----------------------------------

Ensure that only currently supported software is designated as authorized in the software inventory for enterprise assets. If software is unsupported, yet necessary for the fulfillment of the enterprise's mission, document an exception detailing mitigating controls and residual risk acceptance. For any unsupported software without an exception documentation, designate as unauthorized. Review the software list to verify software support at least monthly, or more frequently.

Safeguard 2.3: Address Unauthorized Software

Asset Type: Software	Security Function: Respond	IG1 IG2 IG3
-----------------------------	-----------------------------------	----------------------------------

Ensure that unauthorized software is either removed from use on enterprise assets or receives a documented exception. Review monthly, or more frequently.

Safeguard 2.4: Utilize Automated Software Inventory Tools

Asset Type: Software	Security Function: Detect	IG2 IG3
-----------------------------	----------------------------------	-----------------------

Utilize software inventory tools, when possible, throughout the enterprise to automate the discovery and documentation of installed software.

Safeguard 2.5: Allowlist Authorized Software

Asset Type: Software	Security Function: Protect	IG2 IG3
-----------------------------	-----------------------------------	-----------------------

Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.

Safeguard 2.6: Allowlist Authorized Libraries

Asset Type: Software	Security Function: Protect	IG2 IG3
-----------------------------	-----------------------------------	-----------------------

Use technical controls to ensure that only authorized software libraries, such as specific .dll, .ocx, and .so files, are allowed to load into a system process. Block unauthorized libraries from loading into a system process. Reassess bi-annually, or more frequently.

Safeguard 2.7: Allowlist Authorized Scripts

Asset Type: Software	Security Function: Protect	IG3
----------------------	----------------------------	-----

Use technical controls, such as digital signatures and version control, to ensure that only authorized scripts, such as specific .ps1 and .py files, are allowed to execute. Block unauthorized scripts from executing. Reassess bi-annually, or more frequently.

CONTROL 3

Data Protection

Develop processes and technical controls to identify, classify, securely handle, retain, and dispose of data.

Safeguard 3.1: Establish and Maintain a Data Management Process

Asset Type: Data	Security Function: Govern	IG1 IG2 IG3
------------------	---------------------------	-------------

Establish and maintain a documented data management process. In the process, address data sensitivity, data owner, handling of data, data retention limits, and disposal requirements, based on sensitivity and retention standards for the enterprise. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 3.2: Establish and Maintain a Data Inventory

Asset Type: Data	Security Function: Identify	IG1 IG2 IG3
------------------	-----------------------------	-------------

Establish and maintain a data inventory based on the enterprise’s data management process. Inventory sensitive data, at a minimum. Review and update inventory annually, at a minimum, with a priority on sensitive data.

Safeguard 3.3: Configure Data Access Control Lists

Asset Type: Data	Security Function: Protect	IG1 IG2 IG3
------------------	----------------------------	-------------

Configure data access control lists based on a user’s need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.

Safeguard 3.4: Enforce Data Retention

Asset Type: Data	Security Function: Protect	IG1	IG2	IG3
------------------	----------------------------	-----	-----	-----

Retain data according to the enterprise's documented data management process. Data retention must include both minimum and maximum timelines.

Safeguard 3.5: Securely Dispose of Data

Asset Type: Data	Security Function: Protect	IG1	IG2	IG3
------------------	----------------------------	-----	-----	-----

Securely dispose of data as outlined in the enterprise's documented data management process. Ensure the disposal process and method are commensurate with the data sensitivity.

Safeguard 3.6: Encrypt Data on End-User Devices

Asset Type: Data	Security Function: Protect	IG1	IG2	IG3
------------------	----------------------------	-----	-----	-----

Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.

Safeguard 3.7: Establish and Maintain a Data Classification Scheme

Asset Type: Data	Security Function: Identify	IG2	IG3
------------------	-----------------------------	-----	-----

Establish and maintain an overall data classification scheme for the enterprise. Enterprises may use labels, such as "Sensitive," "Confidential," and "Public," and classify their data according to those labels. Review and update the classification scheme annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 3.8: Document Data Flows

Asset Type: Data	Security Function: Identify	IG2	IG3
------------------	-----------------------------	-----	-----

Document data flows. Data flow documentation includes service provider data flows and should be based on the enterprise's data management process. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 3.9: Encrypt Data on Removable Media

Asset Type:	Data	Security Function:	Protect	IG2	IG3
-------------	------	--------------------	---------	-----	-----

Encrypt data on removable media.

Safeguard 3.10: Encrypt Sensitive Data in Transit

Asset Type:	Data	Security Function:	Protect	IG2	IG3
-------------	------	--------------------	---------	-----	-----

Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).

Safeguard 3.11: Encrypt Sensitive Data at Rest

Asset Type:	Data	Security Function:	Protect	IG2	IG3
-------------	------	--------------------	---------	-----	-----

Encrypt sensitive data at rest on servers, applications, and databases. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.

Safeguard 3.12: Segment Data Processing and Storage Based on Sensitivity

Asset Type:	Data	Security Function:	Protect	IG2	IG3
-------------	------	--------------------	---------	-----	-----

Segment data processing and storage based on the sensitivity of the data. Do not process sensitive data on enterprise assets intended for lower sensitivity data.

Safeguard 3.13: Deploy a Data Loss Prevention Solution

Asset Type:	Data	Security Function:	Protect	IG3
-------------	------	--------------------	---------	-----

Implement an automated tool, such as a host-based Data Loss Prevention (DLP) tool to identify all sensitive data stored, processed, or transmitted through enterprise assets, including those located onsite or at a remote service provider, and update the enterprise’s data inventory.

Safeguard 3.14: Log Sensitive Data Access

Asset Type: Data	Security Function: Detect	IG3
------------------	---------------------------	-----

Log sensitive data access, including modification and disposal.

CONTROL 4

Secure Configuration of Enterprise Assets and Software

Establish and maintain the secure configuration of enterprise assets (end-user devices, including portable and mobile; network devices; non-computing/IoT devices; and servers) and software (operating systems and applications).

Safeguard 4.1: Establish and Maintain a Secure Configuration Process

Asset Type: Documentation	Security Function: Govern	IG1 IG2 IG3
---------------------------	---------------------------	-------------

Establish and maintain a documented secure configuration process for enterprise assets (end-user devices, including portable and mobile, non-computing/IoT devices, and servers) and software (operating systems and applications). Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 4.2: Establish and Maintain a Secure Configuration Process for Network Infrastructure

Asset Type: Documentation	Security Function: Govern	IG1 IG2 IG3
---------------------------	---------------------------	-------------

Establish and maintain a documented secure configuration process for network devices. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets

Asset Type: Devices	Security Function: Protect	IG1 IG2 IG3
---------------------	----------------------------	-------------

Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.

Safeguard 4.4: Implement and Manage a Firewall on Servers

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.

Safeguard 4.5: Implement and Manage a Firewall on End-User Devices

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.

Safeguard 4.6: Securely Manage Enterprise Assets and Software

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Securely manage enterprise assets and software. Example implementations include managing configuration through version-controlled Infrastructure-as-Code (IaC) and accessing administrative interfaces over secure network protocols, such as Secure Shell (SSH) and Hypertext Transfer Protocol Secure (HTTPS). Do not use insecure management protocols, such as Telnet (Teletype Network) and HTTP, unless operationally essential.

Safeguard 4.7: Manage Default Accounts on Enterprise Assets and Software

Asset Type:	Users	Security Function:	Protect	IG1	IG2	IG3
-------------	-------	--------------------	---------	-----	-----	-----

Manage default accounts on enterprise assets and software, such as root, administrator, and other pre-configured vendor accounts. Example implementations can include: disabling default accounts or making them unusable.

Safeguard 4.8: Uninstall or Disable Unnecessary Services on Enterprise Assets and Software

Asset Type:	Devices	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.

Safeguard 4.9: Configure Trusted DNS Servers on Enterprise Assets

Asset Type: **Devices**

Security Function: **Protect**

IG2 **IG3**

Configure trusted DNS servers on network infrastructure. Example implementations include configuring network devices to use enterprise-controlled DNS servers and/or reputable externally accessible DNS servers.

Safeguard 4.10: Enforce Automatic Device Lockout on Portable End-User Devices

Asset Type: **Devices**

Security Function: **Protect**

IG2 **IG3**

Enforce automatic device lockout following a predetermined threshold of local failed authentication attempts on portable end-user devices, where supported. For laptops, do not allow more than 20 failed authentication attempts; for tablets and smartphones, no more than 10 failed authentication attempts. Example implementations include Microsoft® InTune Device Lock and Apple® Configuration Profile maxFailedAttempts.

Safeguard 4.11: Enforce Remote Wipe Capability on Portable End-User Devices

Asset Type: **Data**

Security Function: **Protect**

IG2 **IG3**

Remotely wipe enterprise data from enterprise-owned portable end-user devices when deemed appropriate such as lost or stolen devices, or when an individual no longer supports the enterprise.

Safeguard 4.12: Separate Enterprise Workspaces on Mobile End-User Devices

Asset Type: **Data**

Security Function: **Protect**

IG3

Ensure separate enterprise workspaces are used on mobile end-user devices, where supported. Example implementations include using an Apple® Configuration Profile or Android™ Work Profile to separate enterprise applications and data from personal applications and data.

CONTROL 5

Account Management

Use processes and tools to assign and manage authorization to credentials for user accounts, including administrator accounts, as well as service accounts, to enterprise assets and software.

Safeguard 5.1: Establish and Maintain an Inventory of Accounts

Asset Type: Users	Security Function: Identify	IG1IG2IG3
-------------------	-----------------------------	-----------

Establish and maintain an inventory of all accounts managed in the enterprise. The inventory must at a minimum include user, administrator, and service accounts. The inventory, at a minimum, should contain the person’s name, username, start/stop dates, and department. Validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.

Safeguard 5.2: Use Unique Passwords

Asset Type: Users	Security Function: Protect	IG1IG2IG3
-------------------	----------------------------	-----------

Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using Multi-Factor Authentication (MFA) and a 14-character password for accounts not using MFA.

Safeguard 5.3: Disable Dormant Accounts

Asset Type: Users	Security Function: Protect	IG1IG2IG3
-------------------	----------------------------	-----------

Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported.

Safeguard 5.4: Restrict Administrator Privileges to Dedicated Administrator Accounts

Asset Type: Users	Security Function: Protect	IG1IG2IG3
-------------------	----------------------------	-----------

Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user’s primary, non-privileged account.

Safeguard 5.5: Establish and Maintain an Inventory of Service Accounts

Asset Type: Users	Security Function: Identify	IG2	IG3
-------------------	-----------------------------	-----	-----

Establish and maintain an inventory of service accounts. The inventory, at a minimum, must contain department owner, review date, and purpose. Perform service account reviews to validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.

Safeguard 5.6: Centralize Account Management

Asset Type: Users	Security Function: Govern	IG2	IG3
-------------------	---------------------------	-----	-----

Centralize account management through a directory or identity service.

CONTROL 6

Access Control Management

Use processes and tools to create, assign, manage, and revoke access credentials and privileges for user, administrator, and service accounts for enterprise assets and software.

Safeguard 6.1: Establish an Access Granting Process

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and follow a documented process, preferably automated, for granting access to enterprise assets upon new hire or role change of a user.

Safeguard 6.2: Establish an Access Revoking Process

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and follow a process, preferably automated, for revoking access to enterprise assets, through disabling accounts immediately upon termination, rights revocation, or role change of a user. Disabling accounts, instead of deleting accounts, may be necessary to preserve audit trails.

Safeguard 6.3: Require MFA for Externally-Exposed Applications

Asset Type: Users	Security Function: Protect	IG1IG2IG3
-------------------	----------------------------	-----------

Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.

Safeguard 6.4: Require MFA for Remote Network Access

Asset Type: Users	Security Function: Protect	IG1IG2IG3
-------------------	----------------------------	-----------

Require MFA for remote network access.

Safeguard 6.5: Require MFA for Administrative Access

Asset Type: Users	Security Function: Protect	IG1IG2IG3
-------------------	----------------------------	-----------

Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a service provider.

Safeguard 6.6: Establish and Maintain an Inventory of Authentication and Authorization Systems

Asset Type: Software	Security Function: Identify	IG2IG3
----------------------	-----------------------------	--------

Establish and maintain an inventory of the enterprise’s authentication and authorization systems, including those hosted on-site or at a remote service provider. Review and update the inventory, at a minimum, annually, or more frequently.

Safeguard 6.7: Centralize Access Control

Asset Type: Users	Security Function: Protect	IG2IG3
-------------------	----------------------------	--------

Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.